Ledgerline: Incident Response Plan

Version 2

Approved by Jung Ko, CEO on Oct 14, 2026

Version created Oct 14, 2026; exported Oct 14, 2026

Contents

1. Purpose, scope and authority
2. Roles and responsibilities
3. Incident definitions and severity levels
4. Detection and reporting
5. Response lifecycle
6. Communication plan
7. Notification matrix
8. Evidence handling and documentation
9. Scenario playbooks
10. Testing and maintenance
11. Appendices

1. Purpose, scope and authority

Gives evidence toward: PCI DSS 12.10.1, ISO 27001 A.5.24, NIST CSF ID.IM-04, SOC 2 CC7.4

Purpose

This plan tells Ledgerline staff what to do from the first hour of a security incident: who takes charge, what gets decided, and where to find the next steps. It also serves as the document shown to auditors (SOC 2) and to At-Bay, our cyber insurer, when they ask how we respond.

Scope

The plan covers every system, account and data set Ledgerline relies on, whether we run it or an outside party does:

- Google Workspace (our identity provider, with MFA enforced for everyone)
- GitHub (source code)
- Vercel and AWS, including RDS databases and S3 storage
- Stripe (payments)
- HubSpot (customer records)
- Slack and Linear
- Company laptops and servers, including the endpoint protection on them

It applies to all employees and contractors. It covers customer personal data, source code and financial records. A problem at a vendor, such as a breach at Stripe or HubSpot, is in scope if it could affect our data or customers. Severity levels (SEV1 to SEV3) are defined in a later section.

Authority

- The **Incident Commander (CTO)** has authority to direct the response, assign the **Scribe**, and tell any employee to take, or stop, an action during an incident. If the CTO is unavailable, the Lead Engineer takes over.
- The **Technical Lead (Lead Engineer)** decides on technical containment, such as disabling accounts or rotating keys.
- The **Executive Sponsor (CEO)** must approve the following. The Incident Commander does not decide them alone:
  1. Spending above the agreed limit: [fill in amount]
  2. Paying, or negotiating over, a ransom
  3. Any public statement
  4. Taking a customer-facing system down

If the CEO cannot be reached, the CTO acts as backup Executive Sponsor and records that in the incident log.

Plan owner

The plan owner is the Head of Operations [fill in name], who keeps the plan current and arranges the review every six months. The CEO approves each version.

Version history

Version	Date	Change	Approver
1.0	[date]	Initial version	CEO

2. Roles and responsibilities

Gives evidence toward: PCI DSS 12.10.1, ISO 27001 A.5.24, SOC 2 CC7.4, NIST 800-171 3.6.1

Role	Who	Backup	Responsibility
Incident Commander	CTO	Lead Engineer	Declares the incident and its severity, runs the response, makes the calls nobody else can, and ends the incident.
Technical Lead	Lead Engineer	CTO	Investigates, contains and recovers systems, and keeps the technical timeline.
Communications Lead	Head of Customer Success	Account Manager	Owns every message to staff, customers, partners and the press, and keeps one approved version of each.

Legal and Compliance Lead	Head of Operations with outside counsel	Marlowe & Finch	Works the notification matrix, calls the insurer and outside counsel, and decides what must be reported and when.
Executive Sponsor	CEO	CTO	Approves spending, ransom and shutdown decisions, and speaks for the company to the board and regulators.
Scribe	Assigned by the Incident Commander at the start of each incident (any available team member)	The Communications Lead	Keeps the decision log: every decision, who made it, and the time, as it happens.

Taking over as backup

1. The backup posts in the incident channel in Slack: "I am taking over as [role]."
2. The **Scribe** logs the time and the names of the person handing over and the person taking over.
3. If Slack is not usable, use the phone tree (the list of personal mobile numbers) and have the Scribe log the handover afterwards.

First 15 minutes of a SEV1

A SEV1 means confirmed or likely compromise with active harm. Response starts within 15 minutes at any hour.

1. **Incident Commander (CTO):** declares the SEV1, opens the incident channel, and names the Scribe.
2. **Technical Lead (Lead Engineer):** starts containing the problem. Check Google Workspace sign-ins, AWS (including GuardDuty alerts), GitHub and Vercel for attacker access, and cut off affected accounts first.
3. **Scribe:** starts the decision log with the declaration time.
4. **Communications Lead (Head of Customer Success):** tells staff to stop discussing the incident outside the channel, and holds all outside messages until approved.
5. **Legal and Compliance Lead (Head of Operations):** opens the notification matrix, and calls Marlowe & Finch. At-Bay must be called before any outside help is hired.
6. **Executive Sponsor (CEO):** is told within 1 hour, and is ready to approve spending or shutdown decisions.

Holding two roles

At Ledgerline's size one person may hold two roles, but never the Incident Commander and Technical Lead together, so someone is always free to make decisions while another works the problem.

3. Incident definitions and severity levels

Gives evidence toward: SOC 2 CC7.3, SOC 2 CC7.4, ISO 27001 A.5.24, PCI DSS 12.10.1

What counts as an incident

An **incident** at Ledgerline is any event that has compromised, or is likely to compromise, the confidentiality, integrity or availability of our systems or data. Examples are an attacker in an account, stolen or lost devices, malware, data exposed by mistake, or fraud against our money. A **suspicious event** is something that might be an incident but is not yet confirmed. Report it anyway; the Incident Commander decides.

The following also count as incidents, even when the event happens at someone else:

- A breach or outage at a vendor that holds our data: Google Workspace, GitHub, Vercel, AWS (RDS and S3), Stripe, HubSpot, Slack or Linear.
- A vendor security advisory that says our data or credentials may be exposed.

Severity levels

SEV1 (Critical). Confirmed or likely compromise with active harm. Response starts within 15 minutes at any hour. The **Executive Sponsor (CEO)** is told within 1 hour. The notification matrix (see the notification matrix section) is reviewed the same day.

- An attacker is signed in to a Google Workspace admin account or the AWS account.
- Customer personal data in RDS or S3 is confirmed stolen.
- A fraudulent payout or refund is in progress in Stripe, or ransomware is encrypting laptops or servers.

SEV2 (Serious). Contained or single-system compromise with no confirmed data loss. Response starts within 1 hour during business hours (America/Denver). The Executive Sponsor gets an update the same day.

- One employee's Google Workspace mailbox is taken over.
- The endpoint tool catches malware on one laptop.
- An unencrypted laptop holding source code is lost, or a GitHub personal access token is found exposed in a repository.

SEV3 (Suspicious). Suspicious activity with no confirmed compromise. Reviewed within 1 business day, then closed or escalated in writing.

- A phishing email reported in Slack that nobody clicked.
- A spike in failed Google Workspace logins, even though MFA is enforced for everyone.
- A security advisory from a vendor such as HubSpot or Vercel, or a GuardDuty finding that looks like noise.

Who sets and changes the level

1. Whoever spots the event reports it and gives a first-guess level. When unsure, pick the higher one.
2. The **Incident Commander (CTO)** confirms the level and records it, with the time, in the incident log kept by the **Scribe**. The backup is the Lead Engineer.
3. The Incident Commander raises the level as soon as new facts support it. Lower it only after the **Technical Lead (Lead Engineer)** confirms the harm is contained, and note the reason in the log.
4. Each change of level is told to the Executive Sponsor the same day.

4. Detection and reporting

Gives evidence toward: SOC 2 CC7.3, SOC 2 CC7.4, ISO 27001 A.5.24, NIST 800-171 3.6.1

How to report a concern

Any employee or contractor who sees something odd reports it right away, even if unsure. Examples: a strange email, a login alert from Google Workspace, a lost laptop, an unexpected GitHub or AWS notice, a Stripe payment that looks wrong.

- Post in the Slack security channel or message the **Incident Commander (CTO)** directly. Backup: the **Technical Lead (Lead Engineer)**.
- If Slack or email may be compromised, use the phone tree (personal mobile numbers). Intake phone number: [fill in].
- Nobody is punished for reporting in good faith, including people who clicked a link or lost a device. Reporting late is the real problem.

Alerts that exist today

Source	What it tells us	Who reviews
Endpoint protection (EDR/antivirus) on laptops and servers	Malware or suspicious activity on a device	Technical Lead (Lead Engineer)
AWS alerts (billing, GuardDuty)	Odd activity or unexpected spend in the AWS account	Technical Lead (Lead Engineer)

Review frequency: [fill in]. Alert recipients: [fill in].

Triage procedure

1. The person who receives the report writes down what was seen: who reported it, when, which system, and what happened. Keep screenshots.
2. Tell the Incident Commander (CTO). If unreachable, tell the backup (Lead Engineer).
3. The Incident Commander decides severity within 30 minutes, using the SEV1, SEV2 and SEV3 definitions in this plan. If unsure between two levels, choose the higher one.
4. For SEV1 and SEV2, the Incident Commander opens a dedicated Slack incident channel and assigns a **Scribe** (any available team member) to log times and decisions.
5. For SEV3, log it and review within 1 business day. Close or escalate in writing.
6. For any suspected incident that could lead to a claim, the **Executive Sponsor (CEO)** contacts At-Bay before engaging outside help. See the notification matrix section for deadlines.
7. If the Incident Commander upgrades or downgrades severity, the Scribe records the time and reason.

Gaps to close

Monitoring is thin. Today there is no alerting on Google Workspace sign-ins, GitHub, Vercel or Stripe, and no log review is described. Assign the Technical Lead to:

- turn on Google Workspace alerts for suspicious logins and admin changes;
- send GuardDuty and billing alerts to a shared mailbox or Slack channel, not one person;

- enable GitHub and Stripe security notifications.

Owner and target date: [fill in]. There is no forensics retainer, so contact At-Bay for its panel firm.

5. Response lifecycle

Gives evidence toward: NIST 800-171 3.6.1, SOC 2 CC7.4, ISO 27001 A.5.26, SOC 2 CC7.5

This section is the step-by-step playbook. Severity levels (SEV1, SEV2, SEV3) are defined in the severity section; notification deadlines are in the notification matrix section. Do not restate them here.

1. Preparation

Done before any incident, checked at each six-month plan review.

1. The **Incident Commander (CTO)** keeps the phone tree (personal mobile numbers of all role holders and backups) current and printed or stored outside Google Workspace and Slack. Last verified: [fill in].
2. The **Technical Lead (Lead Engineer)** confirms MFA (a second sign-in check) is enforced for everyone in Google Workspace, GitHub, AWS, Vercel, Stripe and HubSpot.
3. The Technical Lead confirms GuardDuty and billing alerts in AWS reach at least two people, and that the endpoint (EDR) tool is installed on every laptop and server.
4. The Technical Lead confirms the daily automated AWS snapshots (RDS database and S3 data) are running. They are kept only 7 days, so a problem older than a week cannot be restored from them.
5. Keep At-Bay's claim contact and the Marlowe & Finch contact in the phone tree: [fill in]. There is no forensics retainer, so At-Bay's panel forensics firm is the first call for a SEV1.
6. Run a restore test at least every six months. The last successful test was June 2026.

2. Detection and Analysis

1. Anyone who sees something odd (phishing, an alert, a lost laptop, a strange login) tells the Incident Commander in Slack or by phone. Do not investigate alone.
2. The Incident Commander assigns a **Scribe** and starts a timeline: time, what was seen, who did what, in which system.
3. The Technical Lead checks the sources: the EDR console, AWS GuardDuty and CloudTrail (the log of who did what in AWS), Google Workspace admin sign-in and alert logs, GitHub audit log, Vercel activity log and Stripe dashboard.
4. Decide scope: which accounts, systems and data (customer personal data, source code, financial records) are involved, and whether it is still happening.
5. The Incident Commander assigns SEV1, SEV2 or SEV3 and records the reason. Raise the level if unsure.
6. For SEV1 or any possible claim, the **Executive Sponsor (CEO)** contacts At-Bay before hiring outside help. The **Legal and Compliance Lead (Head of Operations)** brings in Marlowe & Finch and reviews the notification matrix.
7. Preserve evidence: take screenshots and export logs before changing anything. Do not wipe devices.

3. Containment

Stop the spread first; do not delete anything yet.

1. **Identity provider (Google Workspace):** in the Admin console, suspend the affected user, reset the password, sign out all sessions, and remove their app passwords and connected apps. Re-register MFA. If an admin account is involved, reset all super admin accounts and review recent admin changes.
2. **AWS:** disable or delete the affected IAM user's access keys, revoke role sessions, and change the root account password and MFA if in doubt. Isolate affected resources by swapping in a restrictive security group. Do not terminate instances or RDS databases yet; take a fresh snapshot first.
3. **Vercel and GitHub:** rotate deployment tokens and environment secrets, remove unknown members and deploy keys, and revoke suspicious personal access tokens.
4. **Email (Google Workspace):** remove forwarding rules and delegates on affected mailboxes, delete the malicious message from all inboxes using the Security investigation tool, and block the sender.
5. **Stripe and HubSpot:** roll API keys, review recent payouts and bank-detail changes, and pause payouts if payment fraud is suspected.
6. **Devices:** use the EDR tool to isolate infected laptops from the network.
7. If email or Slack may be compromised, move to the phone tree and stop discussing the incident in those channels.
8. Rotate any secret that the attacker could have seen, starting with anything stored in the affected system.

4. Eradication and Recovery

1. Find the entry point (phished login, leaked key, vulnerable dependency) and close it. Remove attacker accounts, rules, tokens and unknown code.
2. Rebuild affected laptops from a clean image rather than cleaning them.
3. Restore from the most recent AWS snapshot taken before the compromise began. Snapshots go back only 7 days, so the Technical Lead checks the date range first. Restore into a new RDS instance or S3 location rather than over the existing one.
4. Before returning a system to use, the Technical Lead verifies and the Incident Commander approves:
   - the entry point is closed and all related credentials are rotated;
   - the restored data is complete and its latest timestamp matches expectations;
   - no unknown users, keys, code commits or deployments remain in AWS, GitHub or Vercel;
   - EDR and GuardDuty show no active alerts on the system;
   - MFA is enforced on every account that touches it.
5. Return systems in stages, with extra monitoring for at least [fill in] days. The Scribe records the time each system returns to use.

5. Post-incident activity

1. The Incident Commander declares the incident closed and the Scribe finalises the timeline, decisions, notifications sent and evidence kept.
2. Hold a review within two weeks of closure, with all role holders. Cover what happened, what worked, what was slow, and what was missing.

3. Record each fix with an owner and a due date in Linear, for example shorter token lifetimes, longer snapshot retention or a forensics retainer.
4. The Incident Commander updates this plan where the review found gaps, and the Executive Sponsor (CEO) approves the changes.
5. Retain the incident record for [fill in].

6. Communication plan

Gives evidence toward: SOC 2 CC7.4, ISO 27001 A.5.26, PCI DSS 12.10.1

Nothing goes out to anyone outside the incident team until the **Legal and Compliance Lead (Head of Operations, with outside counsel Marlowe & Finch)** has reviewed it. This applies to email, Slack posts, HubSpot messages, phone calls, social media and press replies. Deadlines for each notification are in the notification matrix section; this section covers who speaks and how.

Who speaks to whom

Audience	One owner	Notes
Staff	**Incident Commander (CTO)**	Short factual updates; no speculation.
Customers and partners	**Communications Lead (Head of Customer Success)**	Use the customer template below. Enterprise MSA customers have a contractual notice clock; see the matrix.
Regulators (state authorities, GDPR supervisory authority)	Legal and Compliance Lead	Filed only with outside counsel's input.
Law enforcement (FBI IC3, local police)	**Executive Sponsor (CEO)**	Report ransomware, extortion, email compromise or wire fraud the same day.
Insurer (At-Bay)	Executive Sponsor (CEO)	Notify before engaging outside forensics or counsel, because At-Bay may require its own panel firms.
Press and social media	Executive Sponsor (CEO)	Everyone else answers "we have no comment at this time" and refers the request to the CEO.

If an owner is unavailable, the backup named in the roles section takes over.

Internal communication

1. The Incident Commander opens a private Slack channel for the incident and invites only people who need to be in it.
2. The Scribe records every message sent outside the team, with time, sender and approver.
3. Post updates at a steady rhythm: every hour for SEV1, and at least once a day for SEV2.
4. Staff must not discuss the incident in public channels, with customers or on social media.

Out-of-band channel

Slack and Google Workspace email run on the same accounts an attacker may control. If either could be compromised, the Incident Commander moves everyone to the **phone tree** (the list of personal mobile numbers) and uses calls or texts only. Keep the list somewhere not stored in Google Workspace, for example printed copies held by the CEO and the Incident Commander. Phone tree location: [fill in]. Do not discuss details over any channel until the Technical Lead confirms it is safe.

Holding statements

These are drafts. The Legal and Compliance Lead must approve each one before it is sent.

Customers

> Subject: Security notice from Ledgerline
>
> On [fill in date and time], we identified [fill in: a short, factual description] affecting [fill in: systems or services]. We are investigating with the help of [fill in: outside specialists, if any]. At this time we [fill in: do / do not] believe your data was affected. We will update you by [fill in time]. Contact: [fill in name, phone, email].

Staff

> We are responding to a security incident affecting [fill in]. Please [fill in: for example, do not use X, change your password]. Do not discuss this outside the company or post about it. Send any press or customer questions to [fill in role]. Next update at [fill in time] via [fill in channel].

7. Notification matrix

Gives evidence toward: SOC 2 CC7.4, NIST CSF ID.IM-04

This table lists every notification duty we know of for Ledgerline. Each clock starts at the moment described in the Trigger column, so the first job in any incident is to write that moment in the decision log.

Obligation	Trigger	Deadline	Owner
US state breach notification laws	Unauthorized access to, or acquisition of, personal information of residents of a state	Varies by state: most require notice to individuals without unreasonable delay, many within 30 to 60 days of discovery, and several require notice to the state Attorney General	Head of Operations with outside counsel
GDPR (Articles 33 and 34)	A personal data breach involving EU or UK residents	72 hours to the supervisory authority after becoming aware; affected individuals without undue delay when the risk to them is high	Head of Operations with outside counsel

Customer contracts	A confirmed incident affecting a customer's data or service, as the contract defines it	Enterprise MSA requires notice within 72 hours	Head of Customer Success with Head of Operations with outside counsel
Cyber insurance (At-Bay)	Any suspected incident that could lead to a claim, before engaging outside help	As soon as possible: many policies require notice within 24 to 72 hours and the use of the insurer's panel counsel and forensics firm	CEO
Law enforcement (FBI IC3, local police)	Ransomware, extortion, business email compromise or wire fraud	No legal deadline; report the same day. A fraudulent wire can only be recalled within hours	CEO

How to use this table

- When an incident is declared, the Legal and Compliance Lead (Head of Operations with outside counsel) copies this table into the incident channel and marks each row as applies, does not apply, or unsure.
- Unsure rows go to Marlowe & Finch the same day. Deadlines are as we understand the law or contract; confirm with counsel before relying on one.
- Rows marked as recommended carry no legal deadline but protect the company: insurers can deny a claim for late notice, and a fraudulent wire can only be recalled within hours.
- When a deadline is met, record who notified whom, when, and how, in the decision log, and keep a copy of what was sent.

8. Evidence handling and documentation

Gives evidence toward: SOC 2 CC7.4, ISO 27001 A.5.26, NIST 800-171 3.6.2, HIPAA 164.308(a)(6)(ii)

Decision log

The **Scribe** (assigned by the **Incident Commander (CTO)** at the start of each incident; backup is the **Communications Lead (Head of Customer Success)**) keeps one running log in a single document, with every entry stamped in Mountain Time. Record:

- what was seen, by whom, and when
- each decision, who made it, and why
- each action taken, who did it, and in which system (for example Google Workspace admin, AWS console, GitHub, Stripe)
- every call or message with At-Bay, Marlowe & Finch, customers or authorities

At-Bay, regulators and SOC 2 auditors will ask what was known, when, and what you did about it. A dated log is the proof. If email and Slack are compromised, keep the log offline and use the phone tree.

Preserve evidence

1. **Do not wipe, reimage or power off** an affected laptop or server. Isolate it instead: disconnect it from Wi-Fi and the network, or use the endpoint tool's isolate function.
2. The **Technical Lead (Lead Engineer)** exports logs before they age out: Google Workspace admin and login audit logs, AWS CloudTrail and GuardDuty findings, and email logs. Also export GitHub and Vercel audit logs. Daily AWS snapshots are kept only 7 days, so take a manual snapshot of any affected RDS database or volume right away.
3. Keep ransom notes as received. Keep phishing emails as original messages with full headers (use "Download message" in Gmail), not screenshots or forwards.
4. Do not delete accounts or messages. Suspend them.

Chain of custody

For every item collected, the Scribe records a line in the log:

What	Collected by	Date and time	Where kept
Example: CloudTrail export	[fill in]	[fill in]	[fill in]

Store items in one restricted folder that only the incident team can open. If an item moves to At-Bay's forensics firm or Marlowe & Finch, log who received it and when. Ledgerline has no forensics retainer, so call At-Bay before engaging any outside forensics help.

Do not

- Do not pay, reply to or contact an attacker without Marlowe & Finch and At-Bay agreeing first.
- Do not wipe or power off affected systems.
- Do not discuss the incident on email or Slack if either may be compromised.
- Do not edit or delete log entries; add a correction with a new time stamp.
- Do not post about the incident publicly or to customers before the **Communications Lead** and the **Legal and Compliance Lead (Head of Operations with outside counsel)** approve. See the notification matrix section for deadlines.

9. Scenario playbooks

Gives evidence toward: SOC 2 CC7.4, ISO 27001 A.5.26, NIST 800-171 3.6.1, PCI DSS 12.10.1

Each runbook covers the first hour. The **Incident Commander (CTO)** opens the incident, assigns the **Scribe** and starts a written timeline (time, who, what was done). The **Technical Lead (Lead Engineer)** runs the technical steps. If Slack or email may be compromised, switch to the phone tree (the list of personal mobile numbers) before discussing details. Notification deadlines are in the notification matrix section, not repeated here.

Ransomware

Ransomware is malware that encrypts files and demands payment. This is SEV1 if encryption is active.

1.

The person who sees it unplugs the laptop from Wi-Fi and network. Do not power it off and do not delete anything. Tell the Incident Commander by phone.

2. The Incident Commander declares SEV1, assigns the Scribe and tells the **Executive Sponsor (CEO)** within the hour.
3. The Technical Lead checks the EDR (endpoint protection tool) for which laptops or servers are affected and isolates them from the console.
4. In Google Workspace, sign out all sessions and reset passwords for affected users. In GitHub, review recent pushes and revoke personal access tokens for those users.
5. In AWS, check GuardDuty findings and review RDS and S3 for unexpected changes or deletions. Do not delete or modify the existing snapshots.
6. Confirm the latest daily AWS snapshot is clean. Snapshots are kept only 7 days, so copy the last known-good snapshot to a protected location before anything ages out. Restore only after the cause is found. The last restore test was June 2026.
7. The CEO notifies At-Bay before engaging any outside help, and reports to FBI IC3 the same day.
8. Do not pay or reply to the attacker. At-Bay and counsel decide that.

Escalate: call At-Bay and Marlowe & Finch immediately on any confirmed encryption or extortion demand. There is no forensics retainer, so use the firm At-Bay names.

Business email compromise

Business email compromise (BEC) is an attacker using a taken-over or spoofed mailbox to trick staff into paying money or sharing data. One taken-over mailbox is SEV2. Payment fraud in progress is SEV1.

1. Stop any payment in progress. Contact the bank and, for Stripe payouts or refunds, Stripe support, and ask to recall or hold the transfer. Recall is only possible within hours.
2. In Google Workspace admin, suspend the mailbox sign-in, reset the password and sign out all sessions. MFA is enforced, so also check for newly added MFA devices or app passwords and remove them.
3. Review the mailbox for forwarding rules, delegated access and filters that hide mail. Delete the malicious ones and save a screenshot first.
4. Use Google Workspace audit logs to list sign-ins from unfamiliar locations and what was read, sent or downloaded.
5. Check whether the account had access to HubSpot, Stripe, GitHub or Slack, and revoke those sessions.
6. The **Communications Lead (Head of Customer Success)** warns staff by phone or the phone tree, not by email, and identifies any customers or vendors who received fraudulent messages.
7. The CEO reports to FBI IC3 the same day.

Escalate: notify At-Bay at once if money moved or customer personal data or financial records were exposed. Bring in Marlowe & Finch via the **Legal and Compliance Lead (Head of Operations)** if personal data was accessed.

Cloud credential compromise

This covers stolen AWS keys, Vercel or GitHub tokens, or a Google Workspace admin account. An attacker inside the identity provider or a cloud account is SEV1.

1.

Incident Commander declares SEV1 and assigns the Scribe. Do not delete resources yet, since logs are evidence.

2. In AWS, deactivate the exposed access keys and attach a deny-all policy to the affected IAM user or role. Revoke active sessions.
3. Review CloudTrail and GuardDuty findings for new users, keys, roles, large S3 downloads, RDS snapshot sharing and unusual regions. Check billing alerts for crypto-mining.
4. In Vercel and GitHub, rotate tokens, deploy keys and environment variables. Check GitHub for new collaborators, OAuth apps and secrets exposed in commits.
5. In Google Workspace, reset passwords and sign out sessions for the affected account. If it is an admin account, review all admin roles and recently created admins.
6. Rotate secrets stored in the app, including database passwords for RDS and Stripe and HubSpot API keys.
7. Technical Lead records which customer personal data in RDS or S3 could have been reached and gives this to the Legal and Compliance Lead.

Escalate: notify At-Bay and Marlowe & Finch as soon as data access is possible, since customer, GDPR and state notification clocks may start.

Vendor breach

This is a breach at a vendor holding Ledgerline data, such as Google Workspace, GitHub, Vercel, AWS, Stripe, HubSpot, Slack or Linear. A vendor advisory alone is SEV3.

1. The person who learns of it sends the vendor notice to the Incident Commander. The Scribe records the date, source and the vendor's exact wording.
2. The Technical Lead identifies what Ledgerline data the vendor holds and which integrations connect to it.
3. Rotate API keys, tokens and passwords for that vendor, and sign out active sessions.
4. Review the vendor's audit logs for Ledgerline activity (for example HubSpot exports, GitHub access logs or Stripe events).
5. Ask the vendor in writing what was accessed and when, and ask for their incident report.
6. The Legal and Compliance Lead checks the vendor contract and the notification matrix to decide whether Ledgerline must tell customers.
7. The Communications Lead prepares a holding statement for customers, to be sent only after counsel approves.

Escalate: contact Marlowe & Finch if customer personal data was involved, and At-Bay if losses or customer claims are possible.

10. Testing and maintenance

Gives evidence toward: PCI DSS 12.10.2, NIST CSF ID.IM-04, SOC 2 CC7.4, NIST CSF ID.IM-02

Exercise schedule

Ledgerline runs at least one tabletop exercise (a talk-through of a made-up incident, with no systems touched) every year. Because the plan is reviewed every six months, run one tabletop at each review: two a year. Scenarios should use Ledgerline's real systems, for example a stolen Google Workspace login, a leaked AWS key in GitHub, or a Stripe payment fraud case.

Role	Part in the exercise
Incident Commander (CTO)	Facilitates and sets the scenario
Technical Lead (Lead Engineer)	Must attend
Communications Lead (Head of Customer Success)	Must attend
Legal and Compliance Lead (Head of Operations)	Must attend; invite Marlowe & Finch
Executive Sponsor (CEO)	Must attend
Scribe	Any team member the Incident Commander picks; records the session

Backups attend if a primary is away. Rotate the Scribe so more people learn the job. Include a check that the phone tree numbers still work, and that the notification matrix is followed, including the 72-hour customer notice.

Evidence each test produces

Within 5 business days the Scribe writes a dated after-action report containing:

1. Date, scenario and attendees.
2. What worked and what did not.
3. Findings, each with a named owner and a due date.
4. Plan changes to make.

Keep every report with the plan. Track findings in Linear until closed. Recheck open findings at the next exercise.

Review triggers

Review the plan within 30 days of any of these, in addition to the six-month review:

- Any SEV1 or SEV2 incident (after its own review).
- A major system change, such as moving off AWS, or adding or replacing Google Workspace, Stripe or another key system.
- An audit finding, including from the SOC 2 audit.
- A change in obligations, such as a new enterprise contract, new regulation or a cyber insurance renewal at At-Bay.
- A change in a role holder or outside party.

Set the next review date at least 60 days before the next SOC 2 audit or insurance renewal: [fill in date].

Approval

1. The Incident Commander (CTO) updates the draft and lists the changes.
2. The Legal and Compliance Lead checks that the notification sections still match Ledgerline's obligations.

3. The Executive Sponsor and plan approver (CEO) approves in writing.
4. Record the version, approval date and approver, then tell all role holders.

An unapproved edit is a draft, not the plan.

11. Appendices

Gives evidence toward: SOC 2 CC7.3, SOC 2 CC7.4, SOC 2 CC7.5

Appendix A: Contact list

Fill in every "[fill in]" cell before the plan is approved. Keep a printed or offline copy, because email and Slack may be down during an incident. If both are down, use the phone tree (the list of personal mobile numbers).

Role	Who	Phone	Email
Incident Commander	CTO (backup: Lead Engineer)	[fill in]	[fill in]
Technical Lead	Lead Engineer (backup: CTO)	[fill in]	[fill in]
Communications Lead	Head of Customer Success (backup: Account Manager)	[fill in]	[fill in]
Legal and Compliance Lead	Head of Operations with outside counsel (backup: Marlowe & Finch)	[fill in]	[fill in]
Executive Sponsor	CEO (backup: CTO)	[fill in]	[fill in]
Scribe	Assigned by the Incident Commander at the start of each incident (backup: the Communications Lead)	[fill in]	[fill in]
Outside counsel	Marlowe & Finch	[fill in]	[fill in]
Cyber insurer	At-Bay (policy number: [fill in])	[fill in]	[fill in]
Managed service provider	None	n/a	n/a
Forensics firm	No retainer in place; ask At-Bay which firm it requires	[fill in]	[fill in]

Appendix B: System inventory

System	What it is used for	Owner (role)	Where it runs
Google Workspace	Company identity provider (sign-in, MFA), email and documents	Technical Lead	SaaS
GitHub	Source code and engineering workflow	Technical Lead	SaaS

Vercel	Hosting and deploying the web app	Technical Lead	Vercel
AWS (RDS and S3)	Databases and file storage, including customer personal data; daily automated snapshots kept 7 days	Technical Lead	AWS
Stripe	Payments and financial records	Legal and Compliance Lead	SaaS
HubSpot	Customer records and communication	Communications Lead	SaaS
Slack	Internal chat	Incident Commander	SaaS
Linear	Issue and project tracking	Technical Lead	SaaS

Monitoring: endpoint protection on laptops and servers, and AWS provider alerts such as GuardDuty and billing alerts.

Appendix C: Control mapping

This table shows which obligations this plan and its tests give evidence toward. It does not by itself make Ledgerline compliant or certified.

Obligation	Control references
SOC 2	SOC 2 CC7.3, SOC 2 CC7.4, SOC 2 CC7.5
Cyber insurance (At-Bay)	No control framework applies; the plan supports the insurer's notice and cooperation conditions, which are set by the policy ([fill in] policy number)